CYBERSECURITY RISK ASSESSMENT REPORT
BOARD OF DIRECTORS GOVERNANCE BRIEFING

Client Name: RetailNova Pty Ltd
Assessment Date: November 2026
Scope: Enterprise Infrastructure (85 Stores, AWS, Hybrid Core)
Prepared By: Senior Cybersecurity Risk Consultant

## EXECUTIVE SUMMARY

RetailNova Pty Ltd operates a large-scale retail enterprise generating $450M in annual revenue across 85 physical store locations and a custom e-commerce platform. A comprehensive risk evaluation of RetailNova's current security posture reveals critical operational vulnerabilities resulting from rapid hybrid cloud adoption coupled with legacy defensive controls. The enterprise's reliance on basic perimeter firewalls, generic antivirus software, and unmanaged Bring Your Own Device (BYOD) access creates substantial exposure to business disruption, regulatory penalties under Australian Privacy Laws, and catastrophic financial losses.

This assessment formally details three primary cybersecurity risks requiring immediate executive governance and capital allocation: enterprise-wide ransomware propagation through interconnected point-of-sale (POS) systems, credential compromise via targeted phishing and unmanaged remote access, and third-party vendor data exposures. Implementing the strategic and technical mitigations outlined herein will transition RetailNova from an inherently vulnerable posture down to acceptable residual risk thresholds, ensuring business continuity, customer trust, and compliance with national statutory frameworks.

## DETAILED RISK ASSESSMENTS

### RISK-01 Ransomware Encryption of POS and AWS Systems

Risk Description: A malicious actor deploys ransomware within an isolated physical store network, exploiting lateral movement paths to traverse store-to-cloud connections into RetailNova's Amazon Web Services (AWS) environment. Failure to isolate point-of-sale (POS) endpoints from central enterprise applications leads to simultaneous encryption of all 85 store POS terminals, e-commerce backend services, and critical ERP databases hosted in AWS, resulting in severe operational paralysis and revenue loss.

Assets at Risk: Physical POS Terminals (85 Stores), AWS Cloud Infrastructure, Custom E-commerce Website, SAP (ERP) System, Revenue Operations ($450M/yr).

Threat: Organized Cybercrime Syndicates deploying automated ransomware variants (e.g., LockBit, BlackCat) via lateral propagation and privilege escalation.
Vulnerability: Lack of network segmentation between store networks and AWS; reliance on basic signature-based antivirus incapable of stopping fileless malware; unmonitored lateral communications.
Existing Controls: Basic perimeter firewalls at store branches and standard legacy antivirus software on store terminals.

Inherent Risk: 3 (Possible) x 4 (Major) = HIGH
Residual Risk: 2 (Unlikely) x 2 (Minor) = LOW

Mitigations:

- Network Segmentation: Implement strict Virtual Local Area Networks (VLANs) and zero-trust firewall rules to isolate store POS networks from corporate subnets and AWS environments.
- Endpoint Detection and Response (EDR): Deploy behavioral EDR across all 85 store locations and AWS virtual machines to replace legacy antivirus and detect lateral movement in real time.
- Immutable Backups: Establish offline, air-gapped, and immutable cloud backups for AWS databases and SAP systems to ensure guaranteed recovery without paying ransoms.
  Risk Owner: Chief Information Security Officer (CISO) / Head of Infrastructure

RISK-02 Phishing Attacks Leading to Credential Compromise
Risk Description: Corporate staff fall victim to sophisticated spear-phishing campaigns designed to capture domain credentials. Adversaries exploit these compromised credentials to establish unauthorized VPN access into the internal network via unmanaged, employee-owned Bring Your Own Device (BYOD) endpoints, providing full access to sensitive enterprise databases and business applications.

Assets at Risk: Corporate Active Directory Credentials, Corporate Remote VPN, Salesforce (CRM), Internal Corporate Subnets, Confidential Business Data.
Threat: Social Engineering Threat Actors, Initial Access Brokers (IABs), and Business Email Compromise (BEC) Specialists.
Vulnerability: Absence of Multi-Factor Authentication (MFA) on VPN gateways; unmonitored BYOD devices lacking security compliance enforcement; reliance on static annual security awareness training.
Existing Controls: Single-factor password authentication on VPN logins; basic annual email security awareness training modules.

Inherent Risk: 4 (Likely) x 4 (Major) = HIGH
Residual Risk: 2 (Unlikely) x 2 (Minor) = LOW

Mitigations:

- Multi-Factor Authentication (MFA): Enforce FIDO2/phishing-resistant MFA across all remote VPN access points, Salesforce, SAP, and internal corporate logins.
- Mobile Device Management (MDM): Require mandatory MDM registration for all corporate and BYOD endpoints accessing internal assets to enforce health checks, encryption, and patch compliance.
- Continuous Phishing Simulations: Transition from static annual training to automated monthly phishing simulations paired with role-based security awareness instruction.
  Risk Owner: Chief Information Officer (CIO) / IT Security Manager

RISK-03 Third-Party Vendor Data Leak
Risk Description: A third-party marketing or logistics service provider with excessive access privileges suffers a security compromise, leading to the unauthorized exfiltration of RetailNova's customer Personally Identifiable Information (PII) such as full names, home addresses, and email addresses. This exposure directly triggers mandatory breach notification requirements under the Australian Privacy Act 1988 (Cth) and Notifiable Data Breaches (NDB) scheme, causing severe regulatory fines and brand devaluation.

Assets at Risk: Customer Personally Identifiable Information (PII), Brand Reputation, Regulatory Standing (OAIC Compliance), Salesforce CRM Data.
Threat: External Threat Actors targeting supply chain vulnerabilities; negligent or compromised third-party vendor personnel.
Vulnerability: Over-privileged third-party vendor access accounts; lack of ongoing vendor compliance monitoring; absence of Data Loss Prevention (DLP) controls over outbound PII transfers.
Existing Controls: Standard vendor non-disclosure agreements (NDAs) and informal contractual security assurances without technical audit mechanisms.

Inherent Risk: 4 (Likely) x 3 (Moderate) = HIGH
Residual Risk: 2 (Unlikely) x 2 (Minor) = MEDIUM

Mitigations:

- Vendor Risk Management (VRM) Program: Institute a formal VRM policy mandating risk assessments, continuous third-party monitoring, and annual security audits.
- Mandatory SOC 2 Type II Certification: Require key marketing and logistics partners to provide independent, annual SOC 2 Type II compliance reports prior to contract execution.
- Data Loss Prevention (DLP) & Least Privilege: Implement DLP solutions to monitor and restrict outbound PII transfers while enforcing strict Role-Based Access Controls (RBAC).
  Risk Owner: Chief Risk Officer (CRO) / Head of Vendor Governance